AI / Tools Declaration — ICS570 Lab 2: Secure Student Records Portal

1. Tools Used

- **Group 1 members:** Elise Oyilonye Kennedy-Angbo (G35532028); Joseph Delali Kodzo Etse (G90412028); Liza Ekua Ndede Aikins (G01322028); Eugene Emmanuel Sewor (G25522028).
- **Libraries & Runtime:** Node.js (`v26.11.1`), Express (`express`), `express-session`, `@simplewebauthn/server` (`v13.2.2`), `webauthn-polyfills` (`v0.1.7`), `curl` for direct HTTP security testing, and Playwright with Chromium's virtual WebAuthn authenticator for the optional real-browser evidence run.
- **AI Assistance:**
- **Google Antigravity** was used to scaffold the Express route structure, WebAuthn options/verification wiring with `@simplewebauthn/server`, the automated FIDO2 test harness (`scripts/run-tests.js`), and formatting of the documentation tables.
- **Claude Code (Anthropic)** was used to review the implementation and documentation against the assignment brief, replace the seeded account emails with the reserved `example.edu` domain, re-run the T1–T8 suite, and draft the group hand-over checklist (`TODO.md`). The group checked its review findings against the source code before acting on them.
- **Claude Code (Anthropic)** was also used to:
  - redesign the browser UI in `public/` (sign-in/enrollment, dashboard, record, roster, Security Lab) while keeping the same stack;
  - add the `GET /courses` summary route;
  - make passkey verification failures return generic error messages, with challenge values masked in the audit log;
  - write `scripts/browser-evidence.mjs`, which captured the real-browser screenshots in `evidence/screenshots/`;
  - update `EVIDENCE_REPORT.md` and split out `PART_B_ADDENDUM.md`.

  The security analysis (Section 3 of the evidence report) was not rewritten by AI. The group reviewed these changes through pull requests on the group repository before merging them. `npm test` was re-run on the merged code: 8/8 PASS plus the logout check.

2. Independent Verification & Testing Performed

- **Passkey Registration & Sign-In (T1–T3):** Verified that `@simplewebauthn/server` validates the one-time session challenge, `expectedOrigin` (`http://localhost:3000`), `expectedRPID` (`localhost`), user presence (`UP`), and ECDSA P-256 signature counter. Confirmed that replaying a captured assertion (`T3`) fails with `HTTP 400` because challenges are immediately deleted from `req.session` upon first verification attempt, and mutating a signature byte fails with `HTTP 401`.
- **Server-Side RBAC & Ownership Enforcement (T4–T8):** Inspected `src/middleware/authz.js` and verified through direct `curl` requests (`T6` and `T7`) that unauthenticated requests receive `HTTP 401`, cross-student record reads (`S001` requesting `/students/S002`) receive `HTTP 403`, and student attempts to call `POST /courses/C101/grades/S001` receive `HTTP 403` while leaving `S001`'s grade unchanged until lecturer `L001` updates it (`T8`).
- **Part B Cryptography Demo:** Verified that `scripts/part-b-crypto-demo.js` generates a fresh 12-byte (96-bit) random nonce via `crypto.randomBytes(12)` on every encryption, restores the exact JSON payload on authorized decryption, and throws an authentication error when either a ciphertext byte or authentication tag byte is modified.
- **Security Analysis & SLS ProSit 2 Connection:** Reviewed and verified all claims in the security analysis against the observed `T1`–`T8` test logs and the Trigger 1 case facts in `ICS570-ProSit2-Who-Can-SLS-Trust.pdf`.